

VirtuEx 시스템 감사 보고서 (2차)

프로젝트: VirtuEx - 가상 자산 모의 거래 플랫폼 차수: 2차 감사 작성일: 2026-03-01 작성: 시스템 감사팀

1. 개요

2차 감사는 1차 감사 이후 추가된 기능 및 기존 코드 전반에 대해 보안, 데이터 무결성, 성능, 프론트엔드 품질, 인프라를 종합적으로 점검합니다. 백엔드 8개 서비스, 프론트엔드, 인프라 구성 전체를 대상으로 수행되었습니다.

1.1 감사 범위

영역	점검 항목 수	발견 이슈
백엔드 보안 및 코드 품질	8개 서비스	25건
프론트엔드 UX 및 품질	컴포넌트/훅/페이지	28건
인프라 및 설정	Docker/Prisma/환경변수/빌드	32건
합계		85건

2. 보안 감사

2.1 발견된 보안 이슈

#	항목	위험도	파일	상태
1	Docker Compose DB 비밀번호 하드코딩	상	docker-compose.yml:14-17	수정 권고
2	WebSocket CORS 검증 미적용	중	price.gateway.ts	수정 권고
3	내부 서비스 엔드포인트 Rate Limiting 부재	중	internal.controller.ts	수정 권고
4	이메일 서비스 민감 데이터 로그 노출	중	email.service.ts:66	수정 권고
5	채팅 참여자 권한 검증 부족	중	chat.service.ts:263,299,344	수정 권고
6	Next.js 보안 헤더 미적용	중	next.config.ts	수정 권고
7	Docker 이미지 버전 미고정 (:latest)	중	docker-compose.yml:95,112 등	수정 권고

2.2 1차 대비 개선 현황

- `.env.example` 민감값 플레이스홀더 교체 ☒
- SMS 코드 프로덕션 마스킹 ☒
- 하드코딩 보안 상수 ConfigService 이관 ☒
- Docker 자격증명 환경변수 패턴 적용 ☒ (단, DB 비밀번호 잔여)

3. 에러 핸들링

3.1 빈 catch 블록 (Silent Failures)

#	항목	위험도	파일	설명
8	가격 알림 에러 무시	중	price-subscriber.service.ts:76,148	<code>.catch(() => {})</code> 패턴으로 에러 로깅 없음
9	주문 프록시 알림 실패 무시	중	order-proxy.controller.ts:53,96	WebSocket 알림 실패 시 무시

10	로그인 로그 생성 실패 무시	하	auth.service.ts:256	감사 로그 누락 가능
11	시세 데이터 발행 실패 무시	중	market-data.service.ts:128	가격 업데이트 누락 가능

권고: 모든 `.catch(() => {})` 패턴을 `this.logger.warn()` 으로 교체하여 최소한 로깅 확보

4. 데이터 무결성

4.1 타입 안전성

#	항목	위험도	파일	설명
12	Balance 서비스 any 타입 사용	중	balance.service.ts:196,262,324	Decimal 값에 any 사용 → 런타임 타입 에러 위험
13	프론트엔드 any 타입 다수	중	LoginSmsModal.tsx:15, useOrders.ts:104	적절한 타입 정의 필요
14	i18n 키 강제 타입 캐스팅	중	orders/page.tsx:640, Ailnsights.tsx:139	as any 로 누락된 키 위험

4.2 입력 검증 부재

#	항목	위험도	파일	설명
15	Portfolio 쿼리 파라미터 미검증	중	portfolio.controller.ts:119,134	limit/offset 무제한 허용
16	내부 API symbol 미검증	중	internal.controller.ts:57,73,89	심볼 형식 검증 없음
17	채팅 헤더 디코딩 미검증	중	chat.controller.ts:47,51,54	크기/구조 제한 없음

4.3 경쟁 조건

#	항목	위험도	파일	설명
18	가격 알림 트리거 경쟁 조건	중	price-subscriber.service.ts:140-144	로컬 캐시 선 갱신 → DB 실패 시 알림 유실
19	뉴스 스크래핑 동시 실행 방지 없음	중	news.service.ts:147-150	@Interval 중복 실행 가능

4.4 Prisma 스키마

#	항목	위험도	파일	설명
20	Order Engine @updatedAt 누락	중	order-engine/schema.prisma:28	수동 DateTime, 자동 갱신 안됨
21	Market Data @updatedAt 누락	중	market-data/schema.prisma 전체	Asset, PriceHistory, Candlestick 등
22	PriceAlert 복합 인덱스 누락	하	user-auth/schema.prisma	(userId, symbol, isActive) 인덱스 필요

5. 인프라 감사

5.1 Docker 구성

#	항목	위험도	상태
23	컨테이너 로깅 설정 미적용	중	수정 권고 - json-file 드라이버 + 용량 제한
24	CPU 제한 미설정	중	수정 권고 - 메모리 제한만 존재
25	pgAdmin/Redis Commander 헬스체크 없음	하	수정 권고

5.2 환경 변수

#	항목	위험도	상태
26	서비스별 DATABASE_URL 미기재	상	.env.example에 mex_* URL 5개 누락
27	서비스 시작 시 환경변수 검증 부재	중	Joi 스키마 기반 검증 권고
28	backup-db.sh 비밀번호 하드코딩 풀백	중	postgres 기본값 제거 권고

5.3 빌드 설정

#	항목	위험도	상태
29	turbo.json 환경변수 의존성 불완전	중	.env* 전체 포함 권고
30	NestJS 버전 불일치 (chat/notification/ai: v10, 나머지: v11)	중	v11 통일 권고
31	Prisma 버전 불일치 (chat: ^6.0.0, 나머지: ^6.3.0)	중	^6.3.0 통일 권고

5.4 Prometheus

#	항목	위험도	상태
32	host.docker.internal macOS 전용	중	Linux 미지원, Docker 내부 DNS 권고
33	scrape_timeout 미설정	하	10초 타임아웃 추가 권고

6. 프론트엔드 감사

6.1 성능

#	항목	위험도	설명
34	AssetListItem React.memo 미적용	상	실시간 가격 업데이트마다 50+개 항목 전체 리렌더
35	WebSocket 구독 해제 누락	상	symbols 변경 시 이전 구독 미해제 → 메모리 누수
36	AssetList 필터 핸들러 useCallback 미적용	중	매 렌더마다 새 함수 생성
37	AI Insights 지연 로딩 미적용	중	대시보드 초기 렌더 지연

6.2 접근성

#	항목	위험도	설명
38	OrderSheet 닫기 버튼 터치 영역 부족	상	20px, 최소 44px 필요
39	BottomNav 일부 아이콘 aria-label 누락	중	스크린 리더 접근 불가
40	아바타/심볼 아이콘 대체 텍스트 없음	중	AssetListItem:99-104

6.3 상태 관리

#	항목	위험도	설명
41	주문 수정 중복 클릭 방지 없음	중	orders/page.tsx:318-328
42	SMS 인증 중복 제출 방지 없음	중	LoginSmsModal.tsx:104-142
43	AI Insights 에러 상태 미표시	중	API 실패 시 null 반환, 에러 안내 없음

6.4 UX

#	항목	위험도	설명
44	채팅방 나가기 확인 모달 없음	상	ChatPanel.tsx:118-126, 실수로 퇴장 가능
45	프로필 수정 버튼 스타일 불일치	중	mypage/edit/page.tsx:149-170
46	ConnectionGuard 메시지 하드코딩	중	i18n 미적용, 인라인 텍스트 객체 사용

7. 코드 품질

7.1 발견 항목

#	항목	위험도	설명
47	에러 메시지 한영 혼용	하	백엔드 전체, 디버깅 시 혼란
48	내부 API Swagger 문서 부재	하	internal.controller.ts, 계약 명세 없음
49	BigInt prototype 전역 변경	하	portfolio/main.ts:14, 사이드이펙트 위험
50	strictPropertyInitialization 비활성	하	tsconfig.base.json:23

8. 종합 평가

8.1 위험도별 분류

위험도	건수	주요 영역
상	8	DB 인증정보 하드코딩, WebSocket 메모리 누수, 리렌더 성능, 채팅방 확인 모달
중	34	입력 검증, 에러 핸들링, 타입 안전성, 인프라 설정, 접근성
하	8	문서화, 코드 스타일, 부가 인덱스
합계	50	

8.2 1차 대비 변화

항목	1차	2차
감사 대상 항목	36건 수정 완료	50건 신규 발견
보안 이슈	5건 수정 완료	7건 신규 권고
인프라	4건 수정 완료	11건 신규 권고
프론트엔드	11건 수정 완료	13건 신규 권고

8.3 즉시 조치 권고 (상 위험도)

1. **Docker Compose DB 비밀번호**: 환경변수 패턴으로 교체 (#1)
2. **AssetListItem 메모이제이션**: React.memo 적용 (#34)
3. **WebSocket 구독 해제**: 이전 symbols unsubscribe 추가 (#35)
4. **OrderSheet 터치 영역**: 44px 이상 확보 (#38)
5. **채팅방 나가기 확인**: ConfirmModal 추가 (#44)
6. **.env.example DB URL 추가**: 서비스별 5개 URL 명시 (#26)

8.4 향후 로드맵

1. 보안 헤더: Next.js HSTS/CSP/X-Frame-Options 적용
2. **NestJS 버전 통일**: chat/notification/ai-service → v11 업그레이드
3. 환경변수 검증: Joi 스키마 기반 부트스트랩 검증
4. **Docker 이미지 버전 고정**: `:latest` → 명시적 버전 태그
5. **pnpm audit**: 의존성 보안 감사 자동화

본 보고서는 VirtuEx 시스템의 2차 감사 결과입니다.